

Section 1: Executive Summary

I analyzed the cloud management dashboard for the HYDROLOGIC water system at The Grand Marina. This dashboard is essentially the control center for monitoring water flow, receiving leak alerts, and remotely shutting off water in the Main Building, Pool and Spa, Kitchen and Laundry areas. Since it controls critical water infrastructure across the entire hotel, anyone who has access to the dashboard has a lot of operational power.

Threat modeling is very important here since the risk is not just about data, it has a real-world impact. The recent \$4.2 million water damage incident shows how costly a failure within monitoring can be. If someone gained unauthorized access to the dashboard, they could disable alerts, adjust system settings, or even trigger the remote shutoff. Even a short disruption could affect guests, staff, revenue and overall the hotel's reputation.

My top three concerns are unauthorized access through stolen credentials, especially multifactor authentication is loosely enforced, overly broad account permissions that give one compromised user control over all systems, and the ability to remote shutoff without any additional verification. Strengthening login protections, limiting access levels and closely monitoring critical actions would dramatically reduce the risk of another costly incident.

Section 2: System Overview

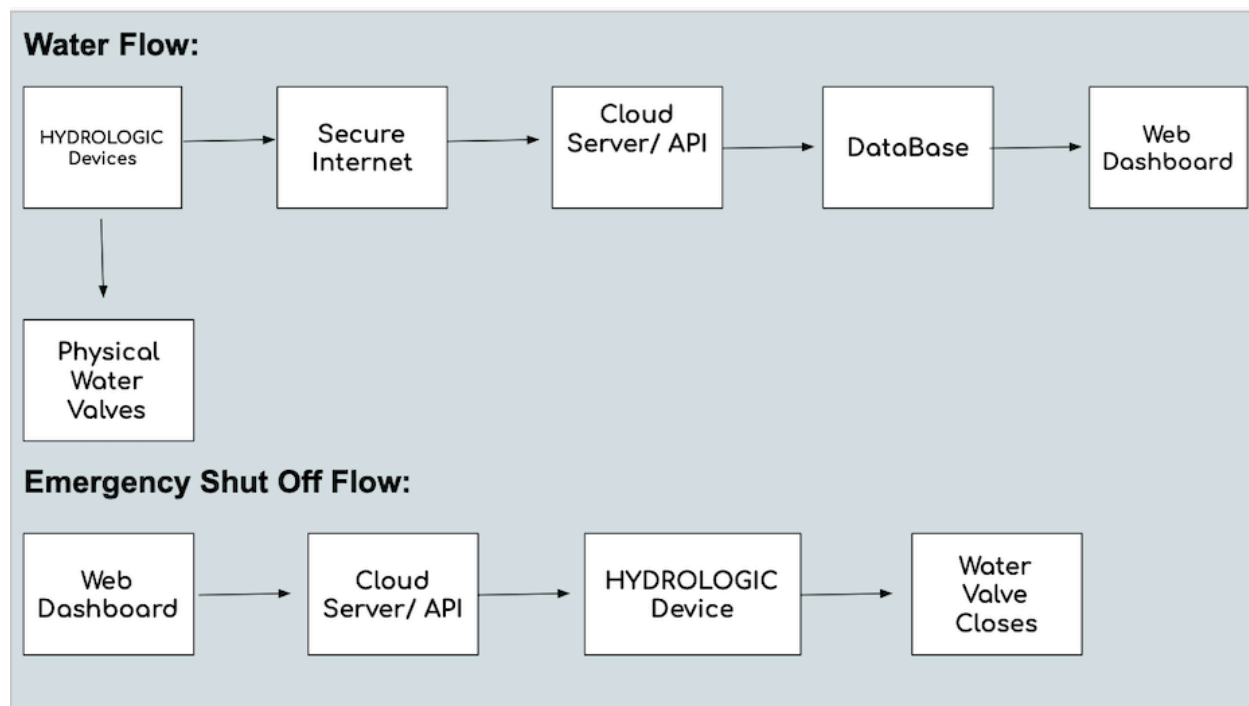
The Grand Marina is a 500-room luxury hotel that uses Hydroficient's HYDROLOGIC system to manage and monitor their water flow operations. The system includes three major physical devices, one on each primary water service line serving the Main Building, Pool and Spa area, as well as the Kitchen and laundry area. These devices monitor water usage in real time and detect potential leaks or abnormal flow patterns.

The major system components include, HYDROLOGIC flow management devices that collect water flow and execute shutoff commands. Cloud server and API infrastructure that receives, processes, and stores device data. A centralized database stores water usage history alerts, and configuration settings. A web-based dashboard used by hotel operators and management. Remote shutoff and gate control mechanisms are connected to each device. This system handles many different types of data, including real-time water flow measurements, leak alerts, device status information, user account credentials, system configuration settings and historical reporting data.

DATA FLOW DESCRIPTION:

Water flow data is first collected by each HYDROLOGIC device. The devices transmit this data securely to Hydroficient's cloud server through an internet connection. The cloud API processes the incoming data and stores it in a centralized database. The web dashboard retrieves this information from the cloud, allowing hotel staff to monitor water usage, receive any alerts and generate reports. If there is a command issued for an emergency shutoff, the command travels from the dashboard to the cloud server and is then sent to the appropriate HYDROLOGIC device. The device executes the command by controlling the physical water valve.

DATA FLOW DIAGRAM:



Section 3: Asset Inventory

List the key assets and their CIA priorities (use your work from Step 2):

Asset	Description	C Priority (confidentiality)	I Priority (integrity)	A Priority (availability)
HYDROLOGIC Devices	3 flow management units	low	Critical	Critical
Web Dashboard	Operator monitoring interface	Medium	Critical	high
Cloud API	Device-to-cloud communication	medium	Critical	Critical
Remote Controls	Gate adjustments, emergency shutoff	low	Critical	Critical
Consumption Data	Savings reports, billing records	high	high	medium

HYDROLOGIC Devices:

- Integrity and availability are the highest priorities since these devices directly control physical water flow. If these commands are altered or the devices go offline, it could lead to operation shutdown or property damage. Confidentiality a low priority since the devices themselves do not store highly sensitive personal data.

Web Dashboard:

- Integrity is critical because unauthorized changes could disable alerts or trigger improper shutoff commands. Availability is important since staff rely on the dashboard for monitoring and response. Confidentiality is a medium priority since login credentials and operational data must be protected, however it is more important that there is no misuse of the control.

Cloud API:

- Integrity and availability are high priorities since the API is the communication pathway between the dashboard and the devices. If it is tampered with or taken offline, commands could be altered or blocked. Confidentiality is medium since it transmits operational data, however exposure alone cannot immediately disrupt any of the physical operations.

Remote Controls:

- Integrity and availability are critical because these functions directly control water valves and gate systems. Unauthorized changes or downtime could cause serious operational disruption. Confidentiality is a low priority since the main risk is misuse of control rather than data exposure.

Consumption Data:

- Confidentiality is high since this data may include billing records and sensitive operational information. Integrity is also high since wrong or altered data could affect reporting and financial decisions. Availability is medium since temporary loss of reporting access would not immediately disrupt physical water operations.

Section 4: STRIDE Analysis

This is the core of your threat model. For **each major component**, analyze all six STRIDE categories:

Component 1: HYDROLOGIC Devices

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Someone pretends to be a device and sends fake water data to the cloud.	low	Critical	Medium
Tampering	Someone gets to a device and changes the firmware so leaks aren't detected or valves don't work correctly.	Low	Critical	Medium
Repudiation	The device doesn't log correctly, so an attacker can shut off water and no one would be able to prove who did it.	Medium	medium	Medium
Info Disclosure	Someone accesses the device and steals credentials or settings	Low	Medium	low
Denial of Service	The device gets hit with too many commands and stops responding, blocking real monitoring.	Medium	Critical	High

Elevation of Privilege	A bug in the device that allows someone to get full control and override all safety functions.	Low	Critical	Medium
------------------------	--	-----	----------	--------

Component 2: Web Dashboard (Same table structure)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Attackers send a fake Hydroficient email to staff, they click a link and the attacker intercepts their login info.	High	High	High
Tampering	Attacker logs in with stolen credentials and changes alert thresholds so leaks aren't noticed.	Medium	Critical	High
Repudiation	Weak logs of not being able to tell who shut water off from the dashboard.	Medium	medium	Medium
Info Disclosure	Attacker downloads consumption reports and billing data using stolen login info	Medium	High	High
Denial of Service	Attacker floods the dashboard or the API with constant requests, locking out real users during a leak	Medium	Critical	High
Elevation of Privilege	Attacker exploits a misconfigured role to turn a low-level account into an admin, allowing full control	Low	Critical	high

Component 3: Cloud API (Same table structure)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Attacker fakes a device or dashboard request using stolen API tokens to send false data to the cloud.	Medium	High	High
Tampering	Attacker intercepts API traffic and modifies data or commands before it reaches the devices.	Low	Critical	Medium
Repudiation	Cloud logs are incomplete, so if an attacker issues them it is unclear on who actually sent them	Medium	Medium	Medium
Info Disclosure	API tokens or keys are exposed in logs or repos and is used to access the cloud	Medium	High	High
Denial of Service	Attacker floods the API with requests, preventing authorized devices and dashboards from communicating.	Medium	Critical	High
Elevation of Privilege	Misconfigured API permissions allow a compromised key to perform actions it shouldn't, allowing the attacker to admin-level access.	Low	Critical	High

Component 4: Remote Controls (Gate/Shutoff) (Same table structure)

Threat	Scenario	Likelihood	Impact	Risk
--------	----------	------------	--------	------

Spoofing	Attacker sends commands to the remote control system pretending to be an authorized dashboard or device.	Low	Critical	High
Tampering	Attacker intercepts or alters shutoff/ gate command within transit so the system executes wrong actions.	low	Critical	high
Repudiation	Weak logs prevent identifying who approved a shutoff or gate commands	Medium	medium	Medium
Info Disclosure	Attacker observes or captures commands within transit, learning when gates are opened or water is shut off.	Low	medium	low
Denial of Service	Attacker floods the control system with repeated commands, preventing real shutoffs or gate operations	medium	Critical	high
Elevation of Privilege	Exploiting a system bug lets the attacker gain full control over remote functions, overriding normal safety controls.	Low	Critical	High

For each scenario, be specific. "Attacker does bad thing" is not acceptable. Describe HOW they would execute the attack.

Section 5: Risk Summary

List your findings by risk level:

Critical Risks:

1. Firmware tampering or device take over such as HYDROLOGIC Devices or Remote Controls: If an attacker modifies firmware or exploits a device bug, they would be able to shut off water or trigger flooding, causing major operational disruption and financial loss.
2. Dashboard or API integrity compromise: Stolen credentials or misconfigured permissions could let an attacker change alert thresholds or issue unauthorized shutoff commands, directly impacting hotel operations and guest safety.
3. Denial of Service on devices or cloud/ API: Flooding key devices or the cloud API could prevent monitoring and response during a leak, risking property damage and operation shutdown.

High Risks:

1. Phishing to capture dashboard credentials: Staff could be tricked into giving away login information, which can then lead to unauthorized control if strict MFA is not put in place.
2. Information disclosure of API token or system settings: Exposure of API keys or device configurations could allow attackers to spoof devices or issue commands.
3. Elevation of privilege via misconfigured roles: Low-level users or stolen keys could gain admin access, allowing dangerous changes to system controls, but requires some existing weakness to succeed.

Medium Risks:

1. Weak logging/ repudiation issues: Actions like shutoffs or configuration changes could be untraceable, making incident investigation harder but not immediately threatening operations.
2. Information disclosure of consumption or billing data: sensitive data exposure could affect financial privacy or reveal operational patterns, but does not directly impact the water flow or guest safety.

Section 6: Recommended Mitigations

For each Critical and high-risk, propose a defense:

Risk	Proposed Mitigation	Implementation Complexity
Firmware tampering or device takeover	Requires signed firmware updates and enable automatic verification before installation on devices	Medium- requires firmware update and testing on all devices

Dashboard or API integrity compromise	Enforce MFA for all users, implement strict role-based access controls and monitor for unusual command activity.	low - configuration changes and policy enforcement
Denial of service on devices or cloud/ api	Rate- limit API requests, add device- level command throttling and implement alerting for abnormal traffic patterns	Medium- configuration changes plus monitoring setup
Phishing to capture dashboard credentials	Train staff of phishing awareness, deploy email filters, and require MFA for all dashboard logins.	Low- staff training and configuration changes
Information disclosure of API tokens or system settings	Store API keys securely using encryption, rotate tokens regularly, and restrict access to authorized personnel only.	Medium- configuration changed and key rotation processes
Elevation of privilege via misconfigured roles	Audit role permissions regularly, of misconfigurations and enforce least amount of access for all users.	Low- periodic audits and configuration updates.